

YOUR WEBSITE IS UNDER ATTACK!



SQL Injection



XSS attacks



Bad Bots



Thousands of
requests hitting
/login

Big question:

HOW DO YOU STOP THEM
BEFORE THEY REACH YOUR
APPLICATION?

INTRODUCING

AWS WAF

Web Application Firewall



Users



Internet



AWS WAF



Your
Application

INSPECT → FILTER → PROTECT



AWS WAF EXPLAINED SIMPLY

AWS WAF (Web Application Firewall) protects your web applications and APIs by **inspecting** HTTP/HTTPS requests and **filtering** unwanted or malicious traffic.

HOW AWS WAF WORKS?



WHAT CAN AWS WAF INSPECT?

- IP Address
- URI Path
- HTTP Headers
- Query Strings
- Cookies
- Request Body

WAF TAKES ACTION

- ✓ ALLOW
- ✗ BLOCK
- 👁️ COUNT
- 🔒 CAPTCHA
- 🛡️ CHALLENGE

KEY BENEFITS

- ✓ Blocks common web exploits like SQLi, XSS
- ✓ Controls bots and abusive traffic
- ✓ Rate limiting & request filtering
- ✓ Protects APIs and web applications
- ✓ Works at **Layer 7** (application layer)



REMEMBER:

AWS WAF sits **in front** of your application and allows good traffic while **blocking** the bad!

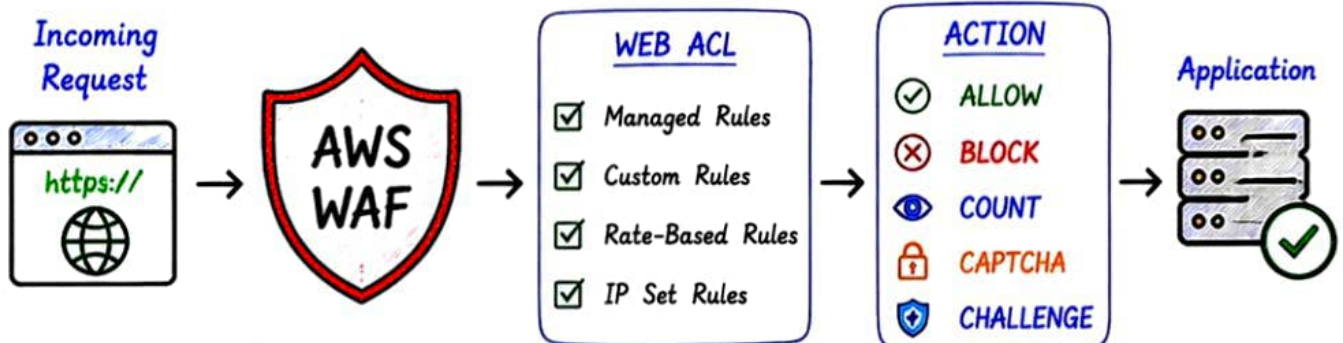




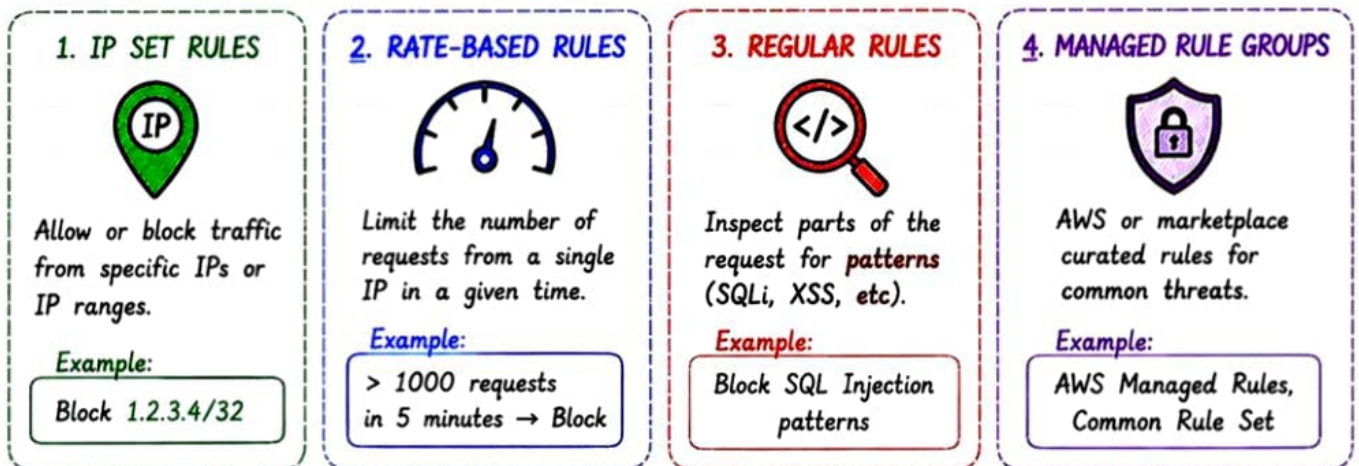
AWS WAF RULES & WEB ACL

AWS WAF uses a Web ACL (Web Access Control List) which contains rules to inspect requests and take action.

HOW AWS WAF EVALUATES A REQUEST



TYPES OF RULES YOU CAN CREATE



RULE PRIORITY (TOP TO BOTTOM)

- 1 WAF evaluates rules in **priority order**.
- 2 First matching rule = **action** is applied.
- 3 If no rule matches → **default action**.

DEFAULT ACTION

If no rule matches:

- ✓ ALLOW by default
- ✗ You can set **DEFAULT BLOCK**



💡 **WEB ACL + SMART RULES = STRONG PROTECTION FOR YOUR APPLICATIONS**



REAL PRODUCTION SCENARIO

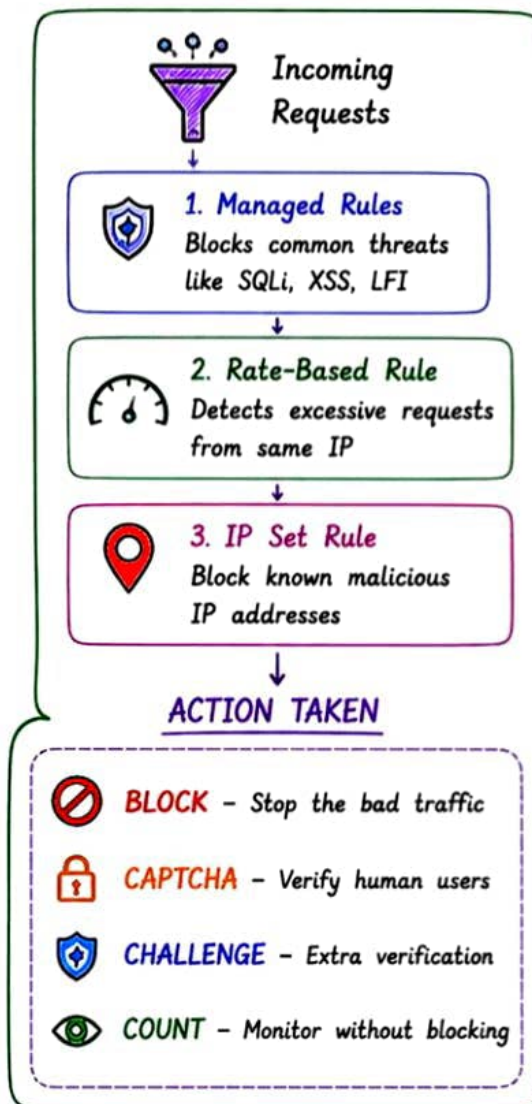
YOUR **/LOGIN** ENDPOINT IS GETTING **HAMMERED!**

Attackers are sending thousands of requests to **/login** to guess passwords (Credential Stuffing Attack)

THE ATTACK FLOW



HOW AWS WAF PROTECTS YOU



WHY RATE-BASED RULES?

- Limit abusive requests from single IP
- Protect sensitive endpoints like /login, /signup, /api
- Stop bots & credential stuffing attempts
- Reduce load on your application

BEST PRACTICE

- ✓ Use AWS Managed Rules
- ✓ Add Rate-Based Rules
- ✓ Monitor in COUNT mode before blocking
- ✓ Tune rules to reduce false positives
- ✓ Enable logging & alerts



REMEMBER:

Don't wait until malicious traffic reaches your servers.
Stop it at the edge with **AWS WAF!**



AWS WAF = BLOCK BAD TRAFFIC EARLY, KEEP YOUR APP SAFE!



WAF vs SHIELD vs SECURITY GROUPS

These 3 services protect your applications, but they work at **DIFFERENT LAYERS!**

	AWS WAF 	AWS SHIELD 	SECURITY GROUPS 
 What it is	Web Application Firewall	Managed DDoS Protection	Virtual Firewall for Your Resources
 Protects Against	Malicious web requests (SQLi, XSS, Bots, etc.)	DDoS attacks (Volumetric attacks)	Unauthorized network access
 Layer	Layer 7 (Application Layer)	Layer 3, 4 & 7 (Network + Transport)	Layer 3 & 4 (Network)
 Operates on	HTTP/HTTPS requests	Network traffic	IP addresses, Ports, Protocols
 Example	Block SQL Injection in /login	Stop a DDoS attack flood	Allow TCP 443 from trusted IP
 Key Point	Inspects & filters web requests	Absorbs & mitigates DDoS traffic	Controls traffic to your resources

EASY ANALOGY

AWS SHIELD



Protects the building from big attacks (DDoS)

AWS WAF



Security guard checks every visitor (web request) before entry

SECURITY GROUPS



Controls which doors (ports) are open to trusted people only

HOW THEY WORK TOGETHER



SUMMARY: Use **SHIELD** to stop attacks, **WAF** to filter bad requests, and **SECURITY GROUPS** to control network access.

TOGETHER = STRONG SECURITY!

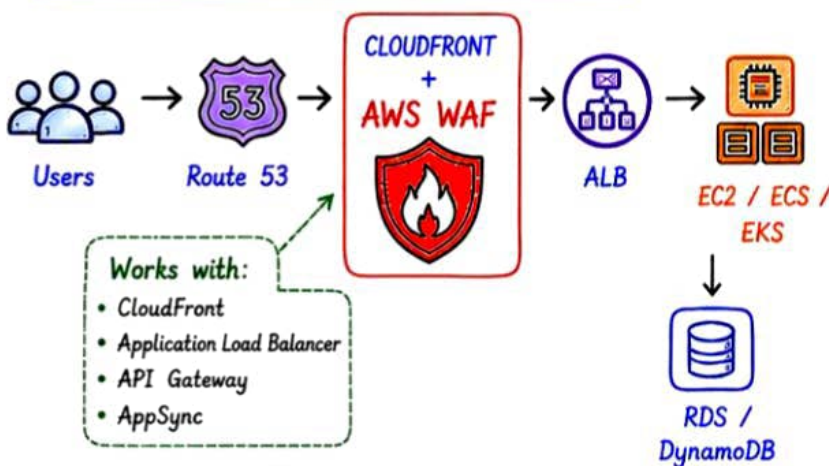


AWS WAF INTERVIEW CHEAT SHEET



Place AWS WAF in front of your application and **stop threats** before they reach your servers!

TYPICAL PRODUCTION ARCHITECTURE



INTERVIEW QUESTION

Q: Your production website is receiving thousands of malicious requests against **/login**. What would you do?

STRONG ANSWER APPROACH ★

- 1 Deploy / verify AWS WAF in front of the application (CloudFront or ALB).
- 2 Enable AWS Managed Rules to block common threats like **SQLi**, **XSS**, **LFI**, etc.
- 3 Add **Rate-Based Rules** to limit abusive requests on **/login** and other sensitive endpoints.
- 4 Use **COUNT** mode first to understand traffic patterns and avoid false positives.
- 5 Monitor WAF metrics, logs & tune rules.
- 6 Consider **CAPTCHA** / **Challenge** for suspicious traffic.
- 7 Combine with **AWS Shield** for DDoS protection.

BEST PRACTICES

- ✓ Start with AWS Managed Rules
- ✓ Use Rate-Based Rules for sensitive endpoints
- ✓ Protect important paths like **/login**, **/signup**, **/api**
- ✓ Use IP sets to allow/block specific ranges
- ✓ Use **CAPTCHA** / **Challenge** to stop bots
- ✓ Monitor & analyze in **COUNT** mode first
- ✓ Enable logging & alerts
- ✓ Regularly review & tune rules
- ✓ Combine with Shield for DDoS protection

WAF ACTIONS

- ✓ **ALLOW** - Let the request through
- 🚫 **BLOCK** - Stop the request
- 👁️ **COUNT** - Log & monitor, don't block
- 🔒 **CAPTCHA** - Verify human users
- 🛡️ **CHALLENGE** - Extra verification before allowing

KEY TAKEAWAY

AWS WAF =
INSPECT → **FILTER** → **PROTECT**
 The earlier you block,
 the safer your applications!



SECURE AT THE EDGE. PROTECT WHAT MATTERS.

